

PLANTILLA DE REPORTE EJECUTIVO EN POWERPOINT

Especificación completa para presentación al Consejo de Administración

Kit GQM+PRAGMATIC DREAD · 18 Diapositivas · Edición 2025–2026

"El Consejo de Administración no necesita saber qué es EPSS. Necesita saber cuánto dinero está en riesgo, cuánto tiempo tienen para actuar y qué tres cosas deben aprobar hoy. Las 18 diapositivas siguientes se ocupan exactamente de eso."

ESPECIFICACIONES GENERALES

Nombre del fichero: Reporte_Ejecutivo_DREAD_GQM_[ORGANIZACIÓN]_[TRIMESTRE].pptx

Dimensiones: 16:9 (1920×1080 px)

Paleta de colores corporativa: Adaptar al manual de marca de la organización

Paleta de seguridad:

- Verde seguridad: #2E8B57 (VERDE oscuro) para estado positivo
- Amarillo alerta: #FFB300 para estado de atención
- Rojo crítico: #C62828 para estado de riesgo elevado
- Azul corporativo: #1565C0 para elementos neutros e informativos
- Gris oscuro: #37474F para texto y fondos

Audiencia: Consejo de Administración, CEO, CFO, CRO, Comité de Riesgos

Duración estimada de la presentación: 25–35 minutos + 10 minutos de Q&A

Frecuencia recomendada: Trimestral (con posibilidad de versión mensual abreviada de 6 diapositivas)

ESPECIFICACIÓN DIAPOSITIVA POR DIAPOSITIVA

DIAPOSITIVA 1 — PORTADA

Título grande (H1): "Evaluación Trimestral de Ciberseguridad"

Subtítulo: "Marco GQM+PRAGMATIC sobre Indicadores DREAD"

Elementos visuales:

- Logo de la organización (superior izquierdo)
- Imagen de fondo: representación abstracta de red/escudo (no alarmista)
- Sello de clasificación de confidencialidad (inferior derecho)

Metadatos en pie de página:

Organización: [NOMBRE] | Período: Q[N] [AÑO] | CISO: [NOMBRE]
Clasificado: CONFIDENCIAL – Uso exclusivo del Consejo de Administración

DIAPOSITIVA 2 — ÍNDICE EJECUTIVO (30 segundos)

Título: "Agenda · 4 Mensajes Clave de Hoy"

Cuatro bloques visuales (iconos + texto):

1.  Posición de riesgo actual — ¿Dónde estamos?
2.  Amenazas prioritarias — ¿Qué nos preocupa?
3.  Evolución trimestral — ¿Estamos mejorando?
4.  Decisiones requeridas — ¿Qué necesitamos aprobar?

Nota para el presentador: "Esta presentación tiene 25 minutos de contenido crítico. Si en algún momento necesitamos profundizar en un tema, lo hacemos. Si el tiempo apremia, las diapositivas 13 a 16 son prescindibles hoy y están disponibles como apéndice."

DIAPPOSITIVA 3 — RESUMEN EJECUTIVO "ONE SLIDE" (2 minutos)

Título: "Estado de la Ciberseguridad · Trimestre [N] [AÑO] · Una vista"

Layout de cuatro cuadrantes:

IGM GLOBAL [XX.X / 100] [Nivel de Madurez] [Color semáforo]	TENDENCIA [Gráfico línea últimos 4 Q] ↑ / → / ↓
TOP 3 RIESGOS PRIORITARIOS 1. [Amenaza KEV] 2. [Amenaza EPSS] 3. [Amenaza DREAD] [Score compuesto]	DECISIONES REQUERIDAS HOY ☐ Aprobar presupuesto X ☐ Autorizar excepción Y ☐ Ratificar política Z

Nota para el presentador: "Este cuadro es la foto completa. El Consejo puede tomar las decisiones de hoy solo con esta diapositiva si el tiempo lo requiere. Las siguientes 15 diapositivas proporcionan el detalle que sustenta cada uno de los cuatro cuadrantes."

DIAPPOSITIVA 4 — PERFIL DE RIESGO DREAD (3 minutos)

Título: "Perfil de Madurez DREAD · Radar de las 5 Dimensiones"

Elemento central: Gráfico radar (spider/web) con:

- 5 ejes: Daño (D), Reproducibilidad (R), Explotabilidad (E), Usuarios Afectados (A), Descubribilidad (Disc)
- Serie 1 (azul sólido): Valores actuales de la organización
- Serie 2 (gris punteado): Benchmark sectorial
- Serie 3 (verde punteado): Objetivo de la organización para fin de año

Tabla de scores bajo el radar:

Dimensión	Score actual	Benchmark	Objetivo FY	Δ vs. Q anterior
D — Daño	[valor]	[sector]	[objetivo]	[flecha + Δ]
R — Reproducibilidad	[valor]	[sector]	[objetivo]	[flecha + Δ]
E — Explotabilidad	[valor]	[sector]	[objetivo]	[flecha + Δ]
A — Usuarios Afectados	[valor]	[sector]	[objetivo]	[flecha + Δ]
Disc — Descubribilidad	[valor]	[sector]	[objetivo]	[flecha + Δ]
IGM Global	[valor]	[sector]	[objetivo]	[flecha + Δ]

DIAPPOSITIVA 5 — DIMENSIÓN D: DAÑO (2 minutos)

Título: "Daño Potencial · Lo que está en juego"

Layout de dos columnas:

Columna izquierda — Métricas:

- ALE: [€/año] — [semáforo]
- IEAC: [%] activos críticos expuestos — [semáforo]
- RTO gap: [horas] — [semáforo]
- TBNO: [%] incidentes con datos personales — [semáforo]
- TMCD: [horas] tiempo medio clasificación — [semáforo]

Columna derecha — Mensaje ejecutivo:

Cuadro de texto con la siguiente estructura:

EN CIFRAS:

"Un ataque sobre [sistema más crítico] podría generar una pérdida de [ALE en €] anuales en el escenario de frecuencia actual."

PROGRESO:

"El RTO gap ha mejorado [X horas] respecto al trimestre anterior gracias a [mejora implementada]."

ACCIÓN PENDIENTE:

"El CMDB requiere actualización para mejorar la precisión del IEAC. Plazo propuesto: Q[N+1]."

DIAPPOSITIVA 6 — DIMENSIÓN R: REPRODUCIBILIDAD (2 minutos)

Título: "Reproducibilidad · ¿Con qué facilidad puede repetirse un ataque?"

Layout:

- Indicador destacado: MTTR por nivel de criticidad (gráfico de barras con colores por urgencia)
- Subindicador TVER: Gauge semicircular mostrando % de vulnerabilidades EPSS>0.5 sin parchear

- Texto ejecutivo: "Actualmente, [N] vulnerabilidades con alta probabilidad de explotación permanecen sin remediar, con una ventana de exposición media de [VEE] días."

Mensaje de negocio: Cada día de retraso en parchear una vulnerabilidad con EPSS > 0.5 aumenta la probabilidad de explotación en [$\Delta\%$] según el modelo FIRST 2025.

DIAPPOSITIVA 7 — DIMENSIÓN E: EXPLOTABILIDAD (2 minutos)

Título: "Explotabilidad · Lo que el atacante necesita para entrar"

Tres indicadores en fila:

1. **CISA KEV:** [N] vulnerabilidades activas en lista KEV — [semáforo rojo/verde]
2. **SMEC CVSS v4.0:** Score medio [X.X/10] — [semáforo]
3. **TMCE:** [X horas] para contener explotación — [semáforo]

Cuadro de alerta (si hay CVEs en KEV):

 **ATENCIÓN URGENTE**
[N] vulnerabilidades actualmente en el inventario figuran en el catálogo CISA KEV, lo que significa que están siendo explotadas activamente en este momento por actores de amenaza confirmados.
Acción requerida: remediación en < [SLA] días.

Cuadro de IA security:

Si E.M3 > 7.0: Destacar vector LLM como amenaza emergente con score [valor].

DIAPPOSITIVA 8 — DIMENSIÓN A: USUARIOS AFECTADOS (2 minutos)

Título: "Alcance del Impacto · ¿A cuántas personas afecta?"

Elemento visual central: Infografía de escala de usuarios

[Icono personas] Usuarios máximos potencialmente afectados:

[UMPA en número grande y llamativo]

Si este número supera 50.000: " Umbral NIS2 de 'gran magnitud'"

Cuadro de cumplimiento regulatorio:

- GDPR (72h notificación AEPD): TMNU actual = [X horas] → [CUMPLE / NO CUMPLE]
- GDPR Art.9 (datos categoría especial): IUVA = [X%] → [nivel de riesgo]
- NIS2 Art.23: TMCD = [X horas] → [< 24h = CUMPLE / > 24h = INCUMPLIMIENTO]

DIAPPOSITIVA 9 — DIMENSIÓN Disc: DESCUBRIBILIDAD (2 minutos)

Título: "Descubribilidad · ¿Qué ve el atacante que nosotros no vemos?"

Mensaje principal: "Perspectiva del adversario"

Tres métricas clave:

- RSAE: "[X%] de nuestra infraestructura es visible externamente sin credenciales"

- RDPR: "En el [X%] de los casos, [nosotros/el atacante] descubrió la vulnerabilidad primero"
- TMDE: "Tardamos una media de [X días] en detectar nuestra propia exposición"

Cuadro de filosofía Zero Trust:

"La estrategia de reducción de la superficie de ataque no consiste en hacer que lo que es vulnerable sea invisible. Consiste en hacer que lo que es visible no sea vulnerable."
– Marco de Resiliencia Digital CNCS 2025

DIAPPOSITIVA 10 — TOP 5 AMENAZAS PRIORITARIAS (3 minutos)

Título: "Las 5 Amenazas que Requieren Atención Inmediata"

Tabla ejecutiva de amenazas (máximo 5 filas, para legibilidad):

#	Amenaza	Score DREAD	EPSS	En KEV	Score Compuesto	Acción Requerida	Propietario	Plazo
1	[nombre]	[X.X]	[0.XX]	SÍ/NO	[XX]	[acción]	[nombre]	[fecha]
2	[nombre]	[X.X]	[0.XX]	SÍ/NO	[XX]	[acción]	[nombre]	[fecha]
3	[nombre]	[X.X]	[0.XX]	SÍ/NO	[XX]	[acción]	[nombre]	[fecha]
4	[nombre]	[X.X]	[0.XX]	SÍ/NO	[XX]	[acción]	[nombre]	[fecha]
5	[nombre]	[X.X]	[0.XX]	SÍ/NO	[XX]	[acción]	[nombre]	[fecha]

Nota visual: Las filas con "En KEV = SÍ" se resaltan en rojo con borde grueso.

DIAPPOSITIVA 11 — CUMPLIMIENTO NORMATIVO (2 minutos)

Título: "Estado de Cumplimiento Regulatorio · NIS2 · DORA · GDPR · ENS"

Tabla de cumplimiento por marco:

Marco	Requisito crítico	Métrica de evidencia	Estado	Último evento
NIS2	Notificación 24h incidente significativo	TMCD	● / ● / ●	[fecha]
NIS2	Gestión de vulnerabilidades	MTTR + TVER	● / ● / ●	[fecha]
DORA	Continuidad TIC	RTO gap + CCUC	● / ● / ●	[fecha]
DORA	Pruebas de penetración	RDPR	● / ● / ●	[fecha]
GDPR	Notificación AEPD < 72h	TMNU	● / ● / ●	[fecha]
GDPR	Protección datos categoría especial	IUVA	● / ● / ●	[fecha]
ENS	Inventario de activos	IEAC	● / ● / ●	[fecha]
ENS	Gestión de parches	MTTR	● / ● / ●	[fecha]

DIAPPOSITIVA 12 — ROI DE LA INVERSIÓN EN CIBERSEGURIDAD (3 minutos)

Título: "Retorno de la Inversión en Ciberseguridad · Justificación Económica"

Layout de dos columnas:

Columna izquierda — Cifras clave:

- Pérdida anual esperada ANTES de inversión: [ALE_actual €]
- Pérdida anual esperada TRAS inversión: [ALE_proyectado €]
- Reducción anual del riesgo: [reducción € y %]
- Inversión total propuesta: [€]
- ROSI (Retorno sobre Inversión en Seguridad): [X%]
- Payback: [X meses]
- VAN a [N] años: [€]

Columna derecha — Gráfico:

Gráfico de barras comparativo: [ALE sin inversión] vs [ALE con inversión] vs [Coste de la inversión amortizado]

Cuadro resumen:

"Invertir [€ inversión] en [mejoras propuestas] tiene un retorno de [X%] anual sobre el riesgo reducido, con recuperación de la inversión en [X meses]."

DIAPPOSITIVA 13 — COMPARATIVA SECTORIAL (2 minutos) [APÉNDICE OPCIONAL]

Título: "¿Dónde estamos respecto al sector?"

Gráfico de barras horizontales comparando IGM_Global y métricas clave de la organización contra:

- Mediana del sector en España (INCIBE 2025)
- Percentil 75 del sector en España
- Media UE (ENISA 2025)

Mensaje: "La organización se sitúa en el percentil [X] del sector [nombre] en España."

DIAPPOSITIVA 14 — EVALUACIÓN PRAGMATIC: CALIDAD DE NUESTRAS MÉTRICAS (1 minuto) [APÉNDICE OPCIONAL]

Título: "¿Podemos confiar en los datos que estamos midiendo?"

Gráfico de dispersión: Puntuación PRAGMATIC (eje X) vs. Puntuación DREAD de la dimensión correspondiente (eje Y). Cuadrante superior-derecho = métricas de alta calidad y alto riesgo.

Mensaje: "Las métricas con baja puntuación PRAGMATIC (especialmente en el criterio de Genuinidad) deben interpretarse con cautela y son candidatas a inversión en automatización de la recogida de datos."

DIAPPOSITIVA 15 — EVOLUCIÓN HISTÓRICA (1 minuto) [APÉNDICE OPCIONAL]

Título: "Evolución del IGM DREAD · Últimos 4 Trimestres"

Gráfico de líneas múltiples: Una línea por dimensión DREAD + una línea gruesa para IGM_Global. El eje X muestra los cuatro últimos trimestres.

DIAPPOSITIVA 16 — PLAN DE ACCIÓN PROPUESTO (2 minutos) [APÉNDICE OPCIONAL]

Título: "Plan de Acción Trimestral · Mejora Priorizada del IGM"

Tabla de iniciativas:

Iniciativa	Dimensión	Métrica impactada	Inversión (€)	ROSI estimado	Plazo	Responsable
[nombre]	[D/R/E/A/Disc]	[ID métrica]	[€]	[%]	[fecha]	[nombre]

Criterio de priorización: Las iniciativas se ordenan por ratio ROSI/coste, priorizando aquellas que mejoran métricas en estado ROJO con mayor puntuación PRAGMATIC.

DIAPPOSITIVA 17 — DECISIONES REQUERIDAS (3 minutos)

Título: "Decisiones del Consejo de Administración · [FECHA]"

Tres bloques de decisión:

DECISIÓN 1 – PRESUPUESTO

Aprobar [€ cantidad] adicionales para [iniciativa concreta].

Justificación: ROSI estimado [X%]

Riesgo de no actuar: [ALE €/año]

☐ APROBADO ☐ APLAZADO ☐ DENEGADO

DECISIÓN 2 – POLÍTICA/EXCEPCIÓN

Autorizar/ratificar [política o excepc.]

Contexto: [descripción breve]

Marco normativo: [NIS2/DORA/ENS/GDPR] |

☐ APROBADO ☐ APLAZADO ☐ DENEGADO

DECISIÓN 3 – OBJETIVOS DE RIESGO

Ratificar el umbral de apetito de riesgo para [dimensión DREAD]: [valor] para el próximo ejercicio fiscal.

☐ APROBADO ☐ APLAZADO ☐ DENEGADO

DIAPPOSITIVA 18 — CIERRE Y PRÓXIMOS HITOS

Título: "Próximos Hitos · Calendario de Ciberseguridad"

Timeline visual horizontal:

[HOY] → [Semana 2] → [Mes 2] → [Fin Q] → [Q siguiente]
Remediación Ejercicio Reporte Auditoría
KEV activos BCP/DRP normativo ENS/NIS2
parcial AEPD

Pie de cierre:

"La ciberseguridad no es un estado que se alcanza.
Es una capacidad que se mantiene."

Próxima presentación al Consejo: [FECHA]

Contacto CIS0: [email] · [teléfono]

NOTAS PARA EL PRESENTADOR: DIEZ REGLAS DE ORO

1. Nunca presentar más de 3 métricas por diapositiva al Consejo. Si necesita más, use el apéndice.
2. Traducir siempre los números a euros o impacto ciudadano. Un Consejo no toma decisiones sobre "MTTR de 15 días"; sí las toma sobre "exposición de 15 días que representa 1,2 M€ de riesgo adicional".
3. El color rojo no es alarmismo; es información. Pero debe ir siempre acompañado de la acción propuesta. Un rojo sin solución es pánico. Un rojo con solución es gestión.
4. Empezar con la diapositiva 3 (One Slide) si el tiempo es limitado. Contiene todo lo que el Consejo necesita para funcionar.
5. Citar las fuentes de los benchmarks. "Según el informe INCIBE 2025..." tiene mucha más credibilidad que "según nuestro análisis interno...".
6. No defender las métricas que están en rojo. Presentar los hechos con honestidad y las soluciones con confianza.
7. Preparar tres respuestas a "¿pero esto no le pasa a todo el sector?": (a) "Sí, y por eso el regulador ha establecido obligaciones legales" (b) "No, el percentil [X] del sector ya lo tiene resuelto" (c) "Sí, pero nuestra posición específica nos hace especialmente vulnerables porque [razón]".
8. La diapositiva 17 (Decisiones) es el propósito real de la reunión. Las demás diapositivas son el camino para llegar a ella bien informado.
9. Dejar la diapositiva 12 (ROI) para el momento de mayor atención del Consejo. La justificación económica es el lenguaje universal del órgano de administración.
10. Cerrar siempre con calendario y próximos hitos. El Consejo necesita saber que hay un proceso continuo, no solo una fotografía trimestral.

Nunca presentar más de 3 métricas por diapositiva al Consejo. Si necesita más, use el apéndice.

Traducir siempre los números a euros o impacto ciudadano. Un Consejo no toma decisiones sobre "MTTR de 15 días"; sí las toma sobre "exposición de 15 días que representa 1,2 M€ de riesgo adicional".

El color rojo no es alarmismo; es información. Pero debe ir siempre acompañado de la acción propuesta. Un rojo sin solución es pánico. Un rojo con solución es gestión.

Empezar con la diapositiva 3 (One Slide) si el tiempo es limitado. Contiene todo lo que el Consejo necesita para funcionar.

Citar las fuentes de los benchmarks. "Según el informe INCIBE 2025..." tiene mucha más credibilidad que "según nuestro análisis interno..."

No defender las métricas que están en rojo. Presentar los hechos con honestidad y las soluciones con confianza.

Preparar tres respuestas a "¿pero esto no le pasa a todo el sector?": (a) "Sí, y por eso el regulador ha establecido obligaciones legales" (b) "No, el percentil [X] del sector ya lo tiene resuelto" (c) "Sí, pero nuestra posición específica nos hace especialmente vulnerables porque [razón]".

La diapositiva 17 (Decisiones) es el propósito real de la reunión. Las demás diapositivas son el camino para llegar a ella bien informado.

Dejar la diapositiva 12 (ROI) para el momento de mayor atención del Consejo. La justificación económica es el lenguaje universal del órgano de administración.

Cerrar siempre con calendario y próximos hitos. El Consejo necesita saber que hay un proceso continuo, no solo una fotografía trimestral.

Plantilla PowerPoint · Documento F del Kit GQM+PRAGMATIC DREAD · Abril 2026

Metodología comunicativa: NACD Cyber-Risk Oversight Handbook; ENISA ECSM Communications Guide